Incident Response Report

Wazuh SIEM Home Lab

Date: April 6, 2026 Analyst: Victoria

SIEM: Wazuh v4.7.5 Agent: 001 (Kali Linux)

Victim IP: 192.168.48.148 SIEM IP: 192.168.48.140

Attacker: Debian 13.x Network: Isolated VMware NAT

1. Overview

I built this home lab to practice real threat detection and incident response using Wazuh SIEM. The setup runs entirely in VMware Workstation with three VMs: a Wazuh server on Ubuntu, a Kali Linux machine as the monitored victim, and a Debian VM as the attacker. I ran a series of attacks including SSH brute forcing, creating rogue root accounts, and tampering with critical system files. Wazuh successfully detected all simulated activity in real time, and I documented the findings in this report.

2. Findings Summary

#	Finding	Severity	MITRE	Rule ID
1	Trojaned system binaries detected	HIGH	T1014	510
2	/etc/shadow modified in real time	CRITICAL	T1565.001	550
3	/etc/sudoers modified in real time	CRITICAL	T1565.001	550
4	Rogue root accounts created (UID 0)	CRITICAL	T1136/T1078	—
5	Defense Evasion: agent stopped 3 times	MEDIUM	T1562.001	506
6	SSH brute force attempted	MEDIUM	T1110	—
7	SSH hardening failures (9 issues)	MEDIUM	—	19007
8	AppArmor policy violations	LOW	—	52002

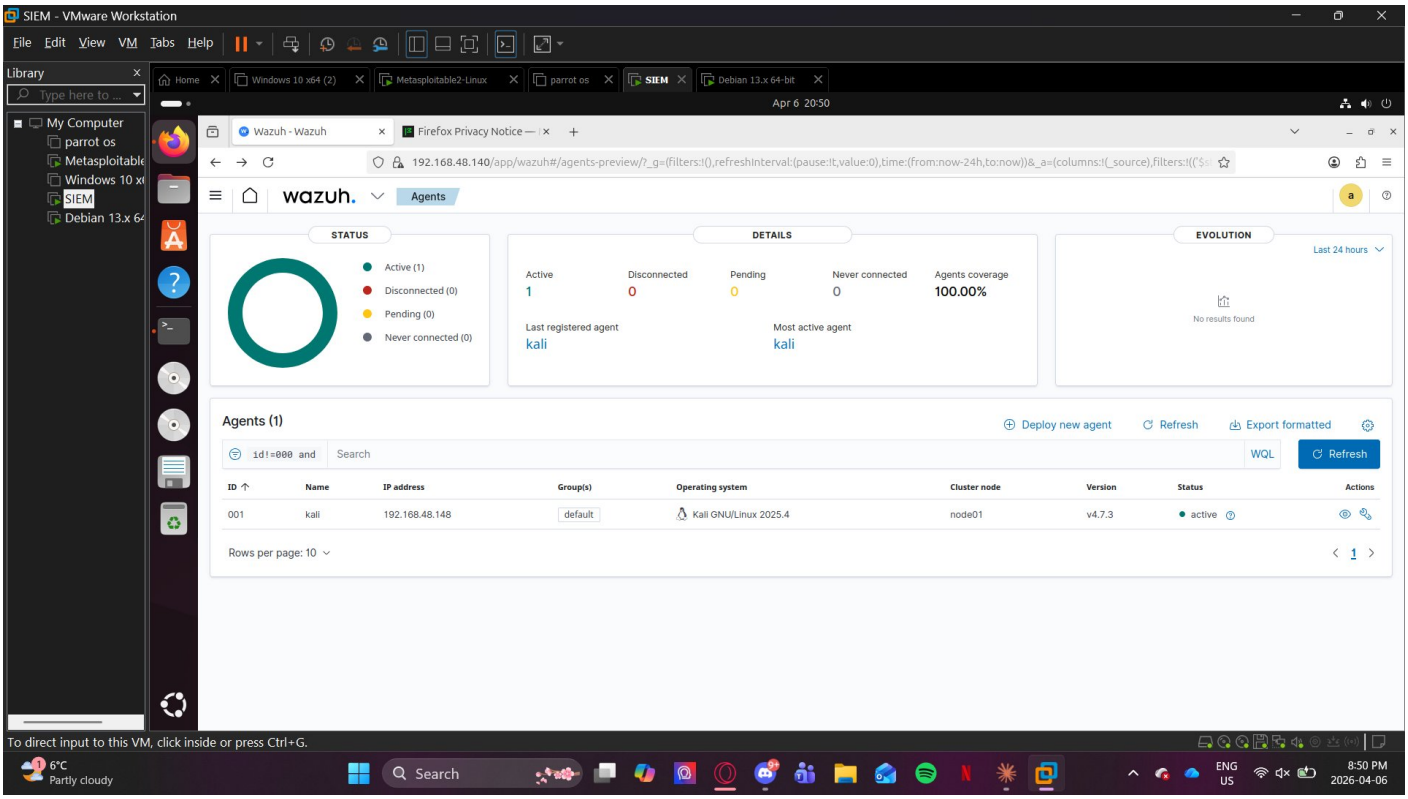

Figure 1: Wazuh agents dashboard showing Agent 001 (Kali Linux) connected and active

3. Attack Timeline

Time	What Happened	Rule
20:49:17	Wazuh agent came online on the victim machine	503
20:49:35	Agent was stopped, Wazuh flagged it as Defense Evasion	506
20:49:39	Trojaned binaries found: /usr/bin/diff, /bin/diff, /bin/chsh, /bin/chfn	510
21:00:59	AppArmor started blocking and logging violations	52002
21:04:52	SSH brute force launched using Hydra with rockyou.txt (14M passwords)	—
21:17:00	Manual failed SSH logins tried against wronguser, admin, root, test	—
21:21:33	Agent stopped again, another Defense Evasion alert fired	506
21:30:08	Privilege escalation via PAM detected, mapped to T1078	5501
21:34:28	Agent stopped a third time	506
21:38:55	/etc/shadow written to, Wazuh caught it in real time	550
21:39:41	/etc/sudoers written to, another real-time FIM alert fired	550
21:39:45	/etc/shadow modified again, Wazuh caught it again	550

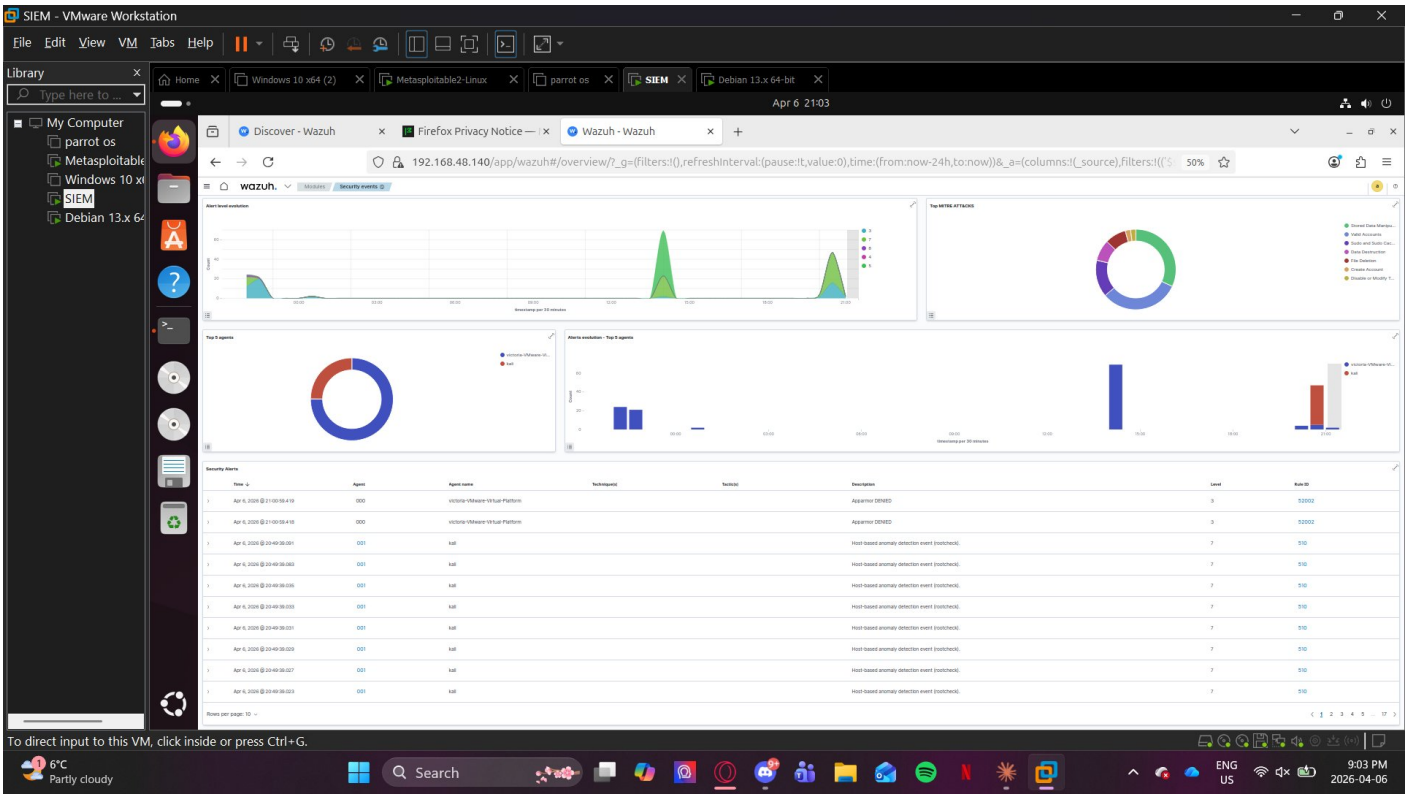

Figure 2: Security Events dashboard showing the alert spike during the attack window

4. Detailed Findings

Finding 1: Trojaned System Binaries

When the Wazuh agent first checked in, rootcheck immediately flagged several system binaries as trojaned. These files had signatures matching known rootkit patterns, indicating the system had been compromised at some point before monitoring began.

```
File: /usr/bin/diff   Title: Trojaned version of file detected   Signature:
bash|*/bin/sh|file.h|proc.h|/dev/[^n]|*/bin/.*sh (Generic)   Rule 510 Level 7 PCI-DSS 10.6.1   GDPR
IV_35.7.d   MITRE T1014
```

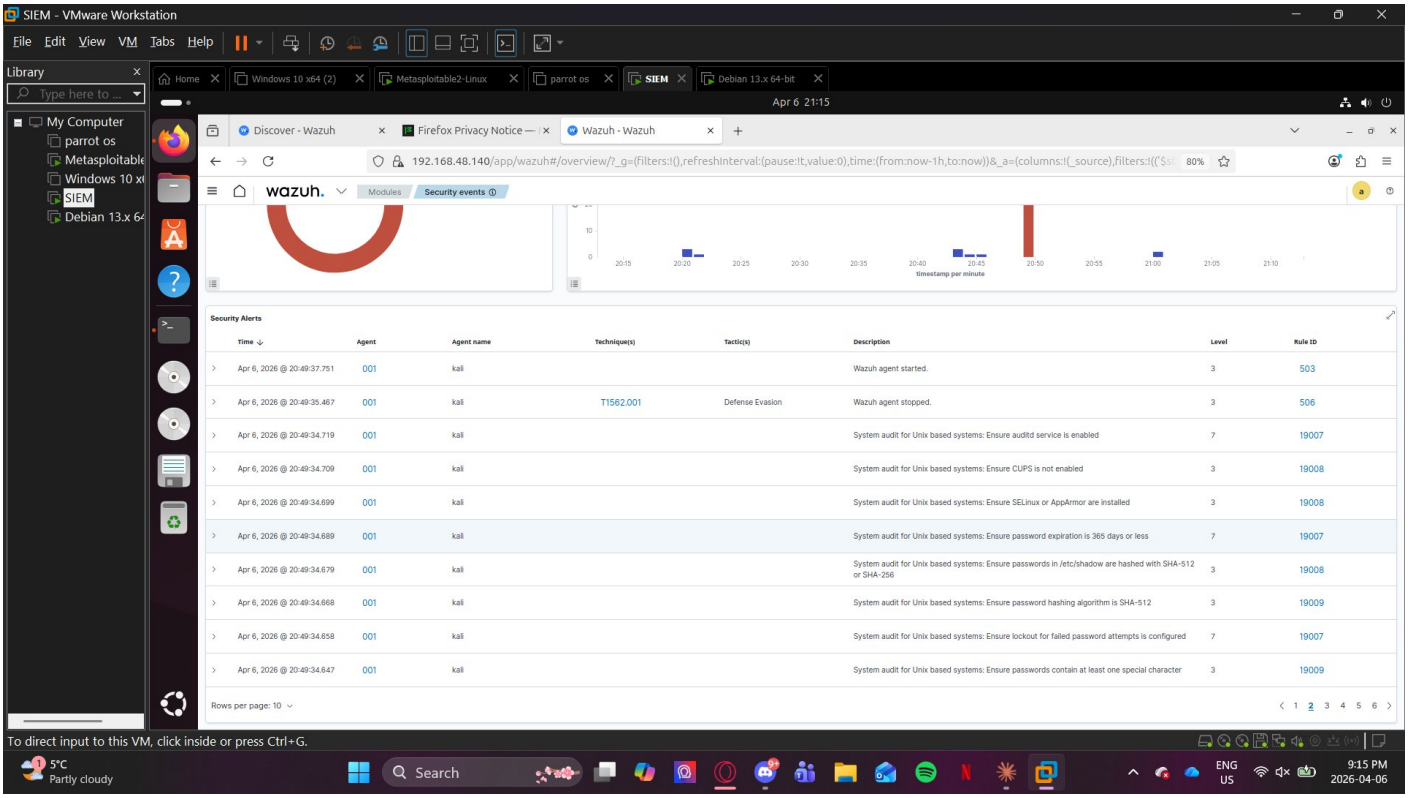

Figure 3: Security alerts showing Defense Evasion T1562.001 and system audit findings

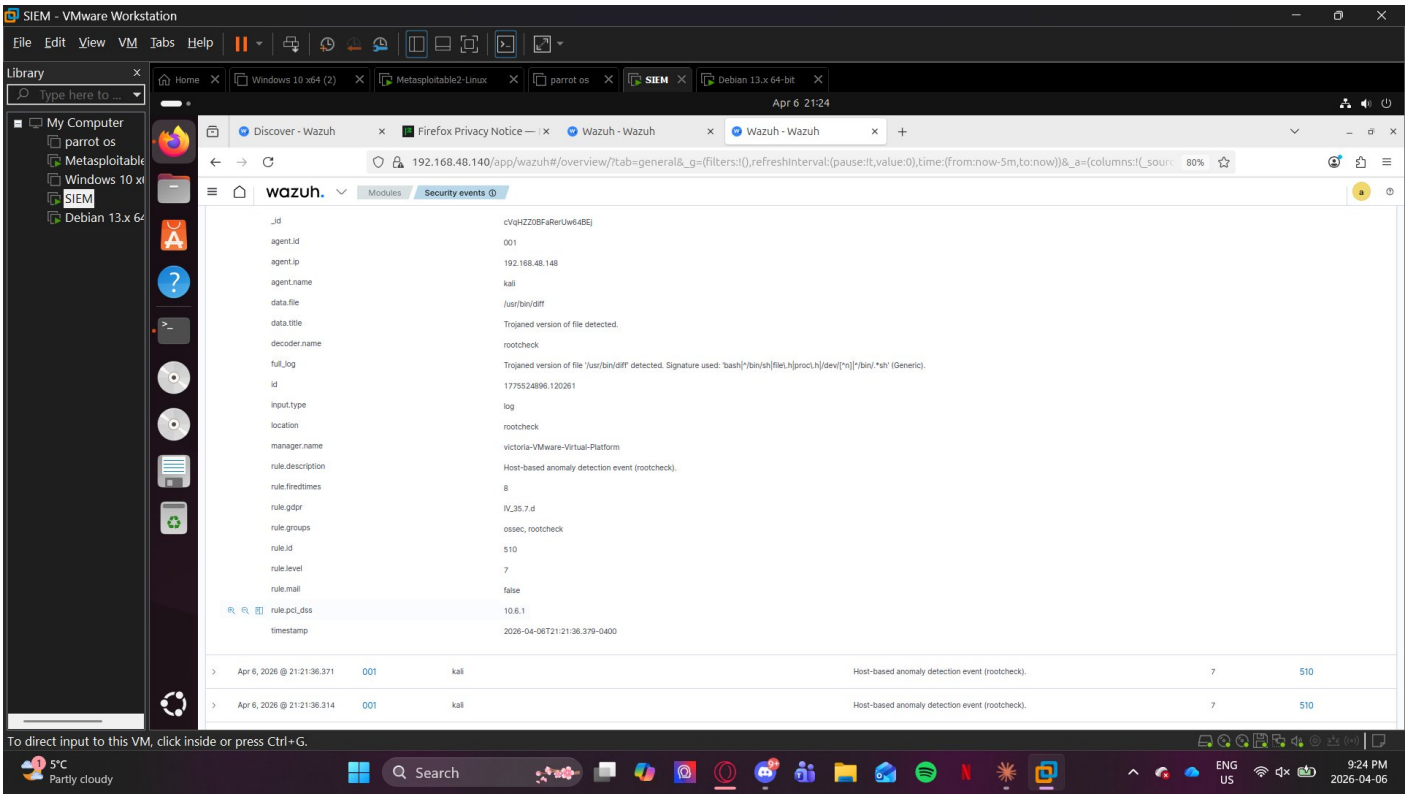

Figure 4: Expanded rootcheck alert showing /usr/bin/diff trojaned binary with full log

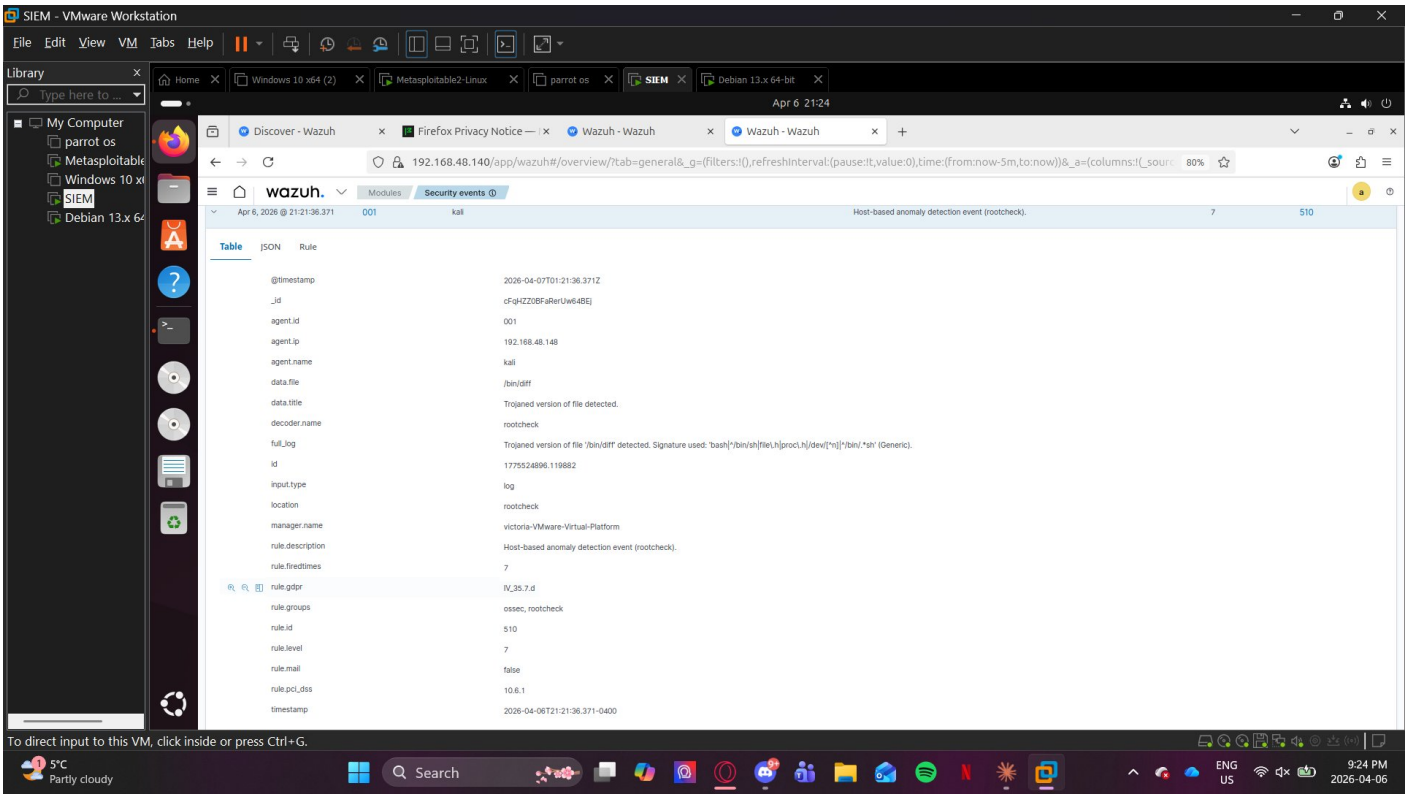

Figure 5: Second trojaned binary alert for /bin/diff with PCI-DSS and GDPR compliance tags

Findings 2 and 3: /etc/shadow and /etc/sudoers Tampered

After enabling real-time FIM on /etc, both /etc/shadow and /etc/sudoers were modified to verify whether Wazuh would detect the changes. Alerts were generated within seconds, including the full before-and-after MD5, SHA1, and SHA256 hashes for each file. This provides clear evidence that the files were modified. Both alerts automatically triggered HIPAA, GDPR, and TSC compliance rules.

```
File: /etc/shadow   Mode: realtime   Changed: size, mtime, md5, sha1, sha256   Size: 1510 to 1515   Old
md5: 4c774f42346a8cde17122b84da408694   New md5: 5143ac6494c04b9dc3e35d428846ea35   MITRE T1565.001
HIPAA 164.312.c.1   GDPR II_5.1.f
```

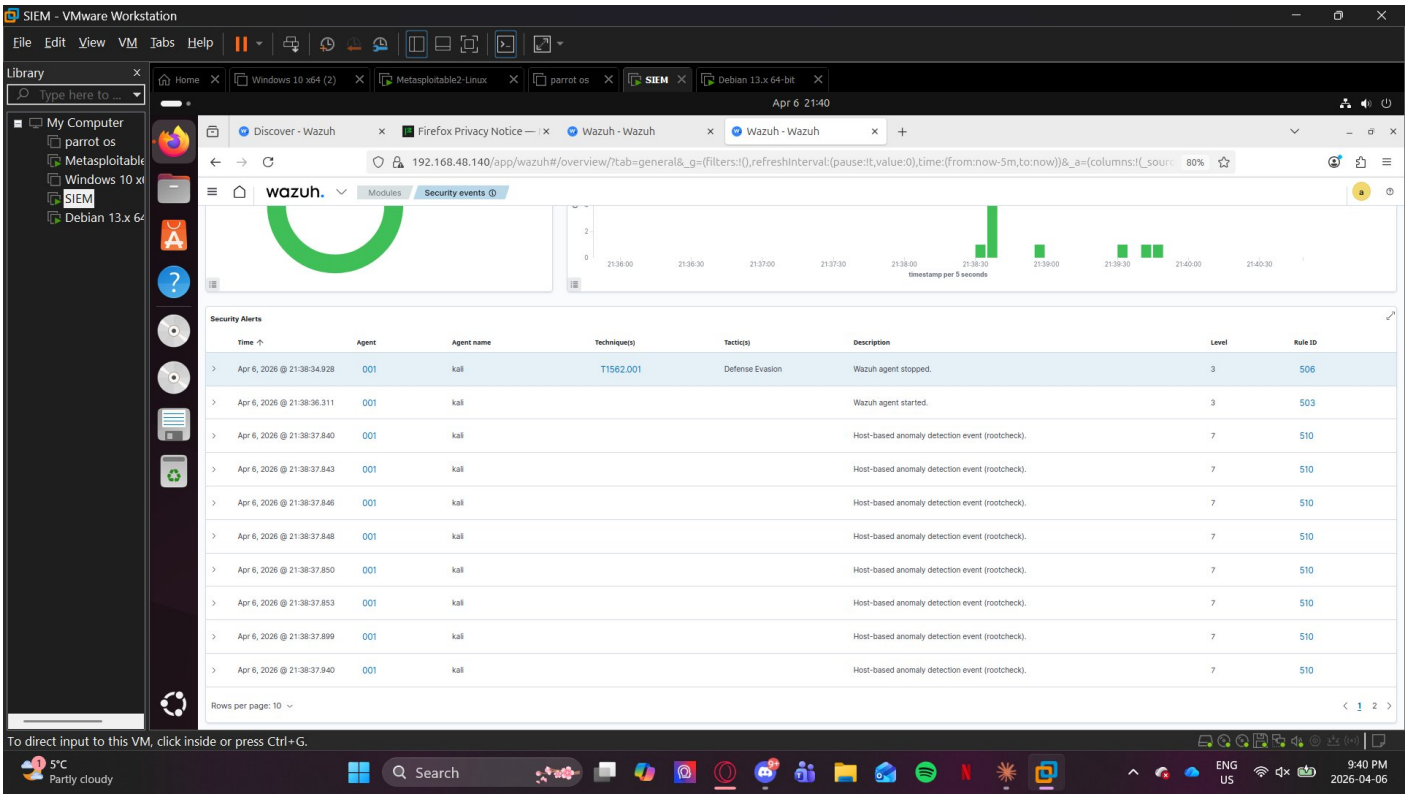

Figure 6: Integrity checksum changed alerts firing in real time, tagged as T1565.001 Impact

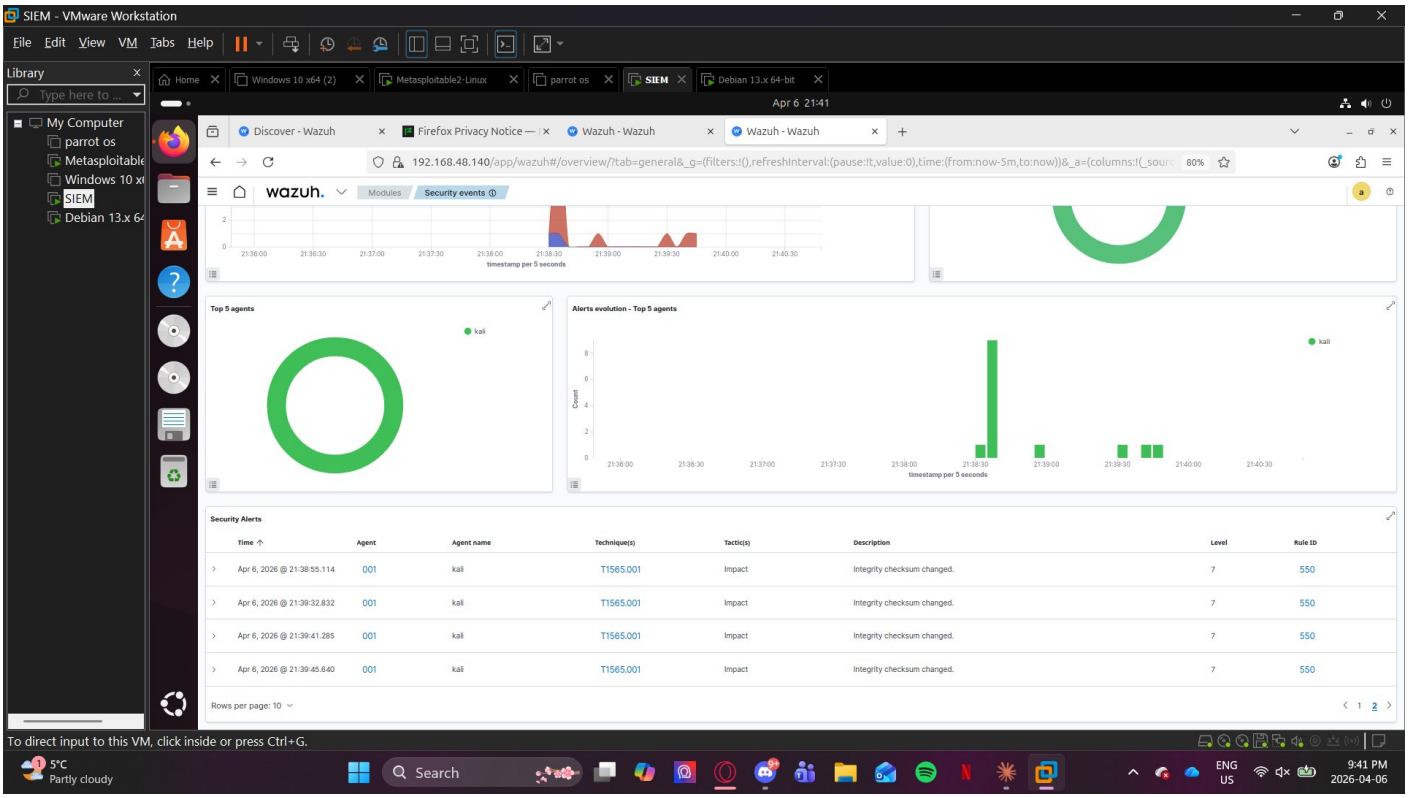

Figure 7: Alert evolution chart showing the spike when the files were tampered with

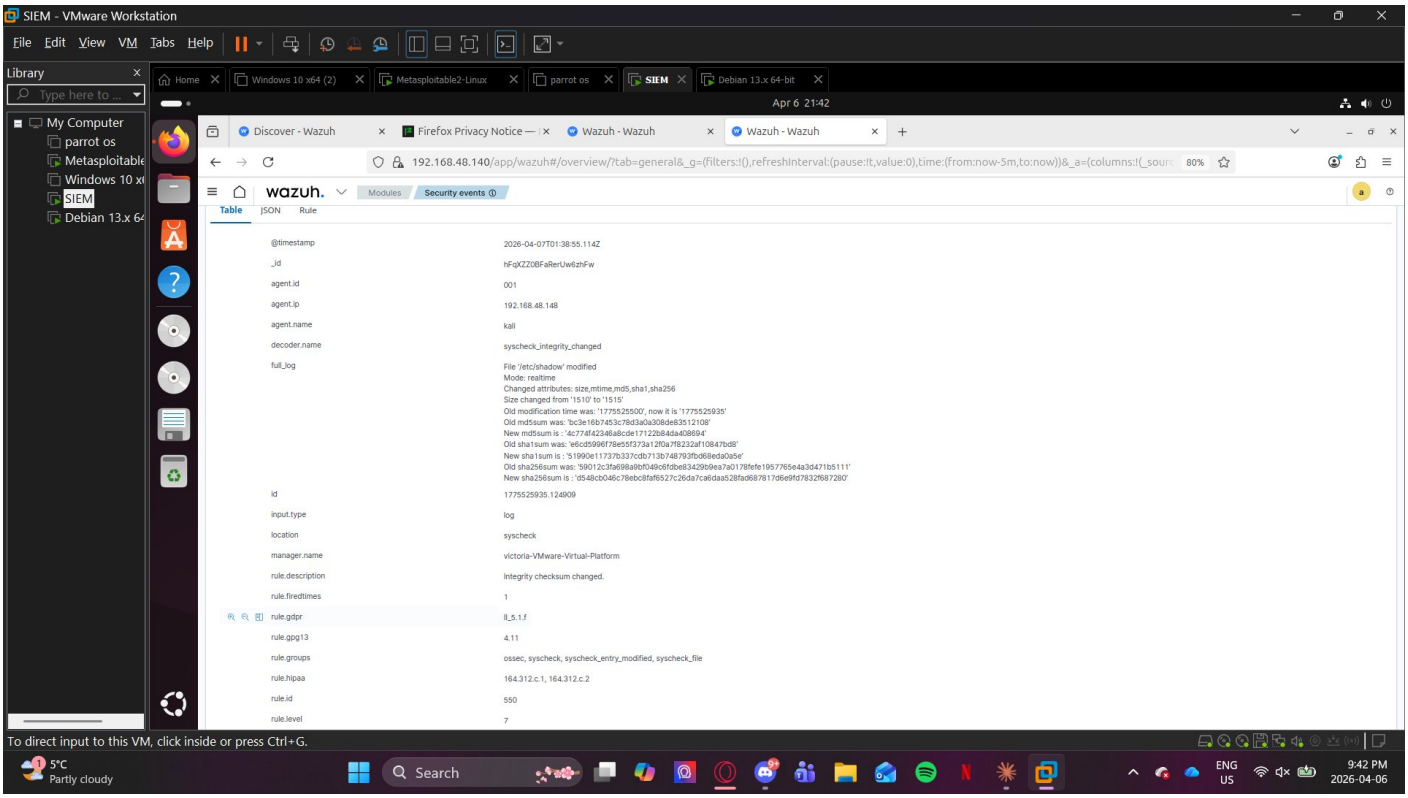

Figure 8: /etc/shadow alert detail showing realtime mode and SHA256 hash comparison

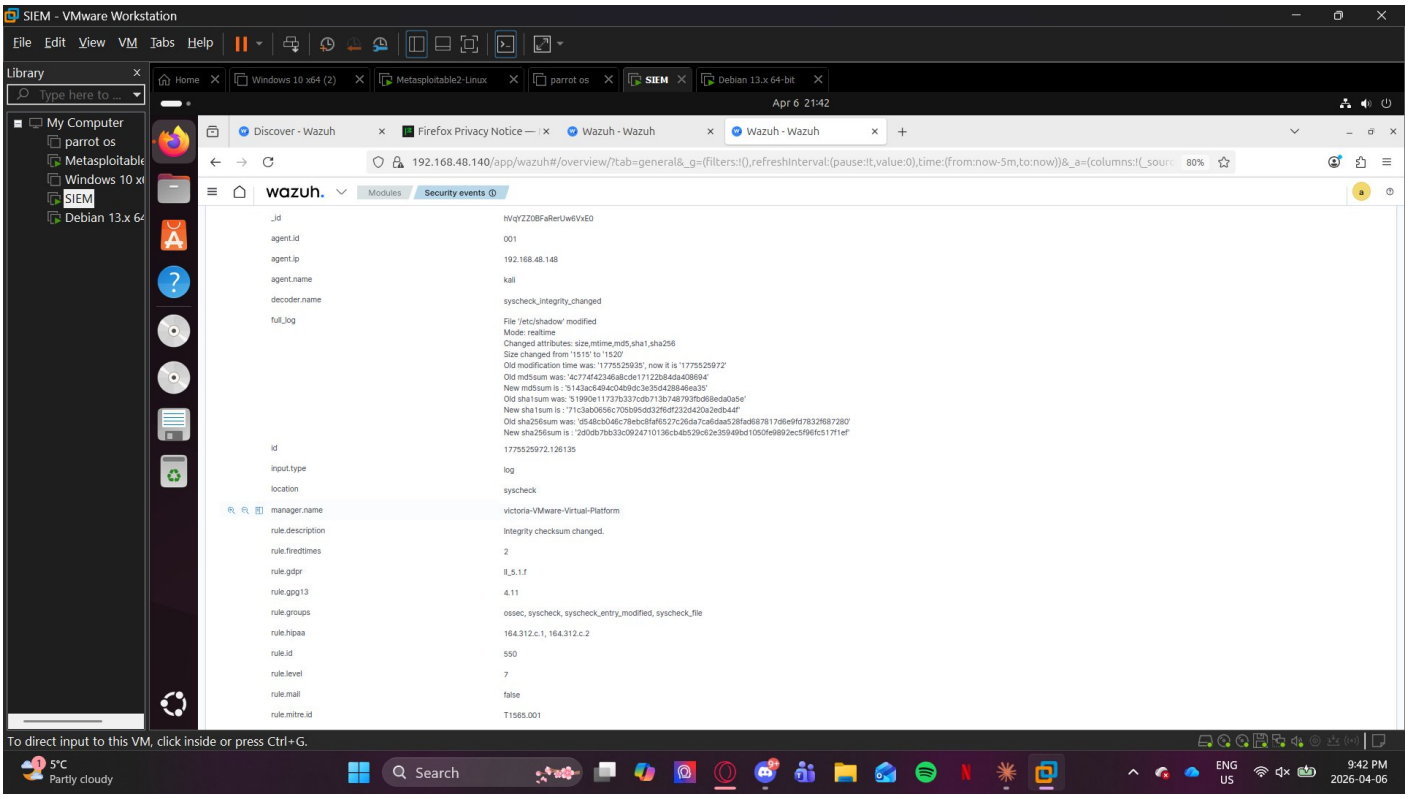

Figure 9: Continued /etc/shadow alert showing MITRE T1565.001, HIPAA 164.312.c.1 and GDPR

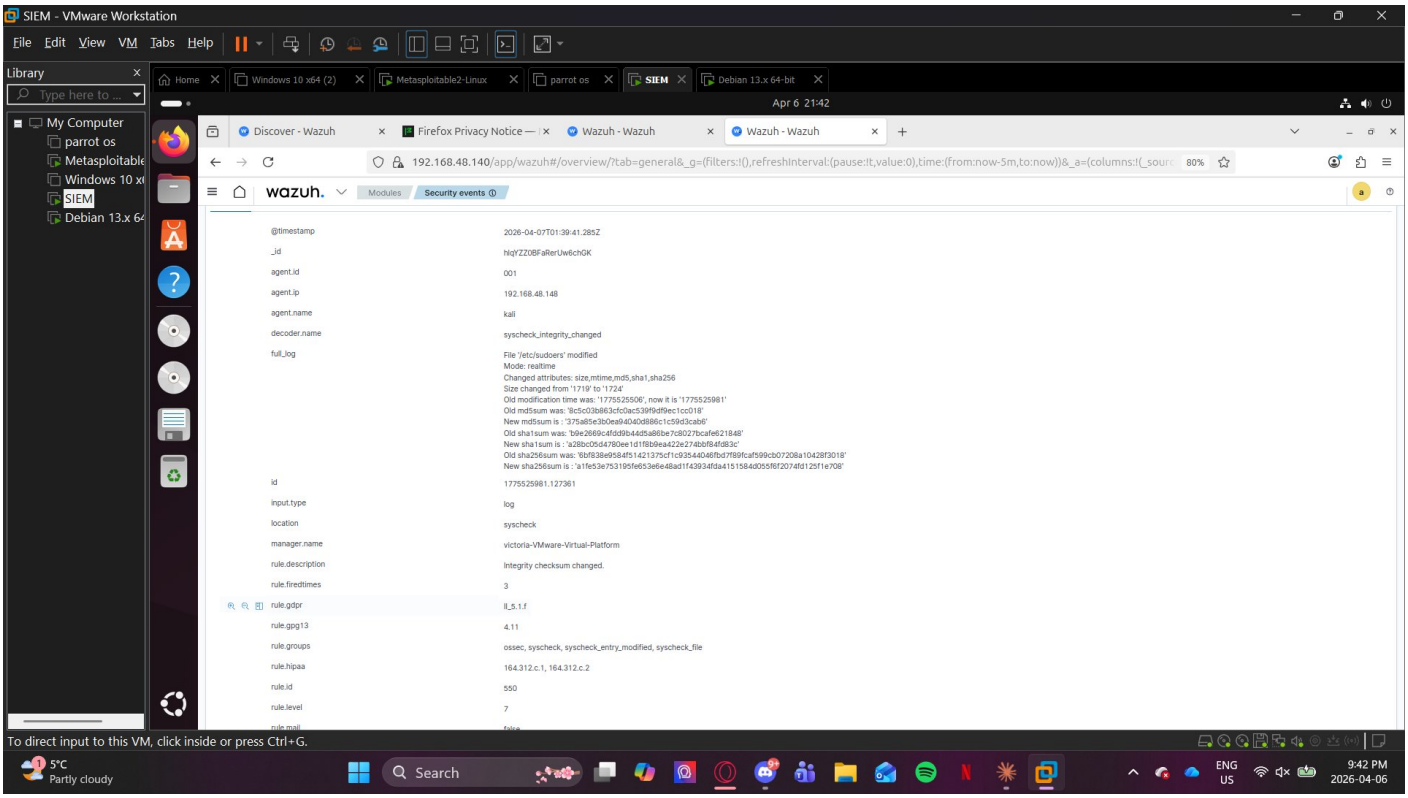

Figure 10: /etc/sudoers modification alert with full forensic syscheck data

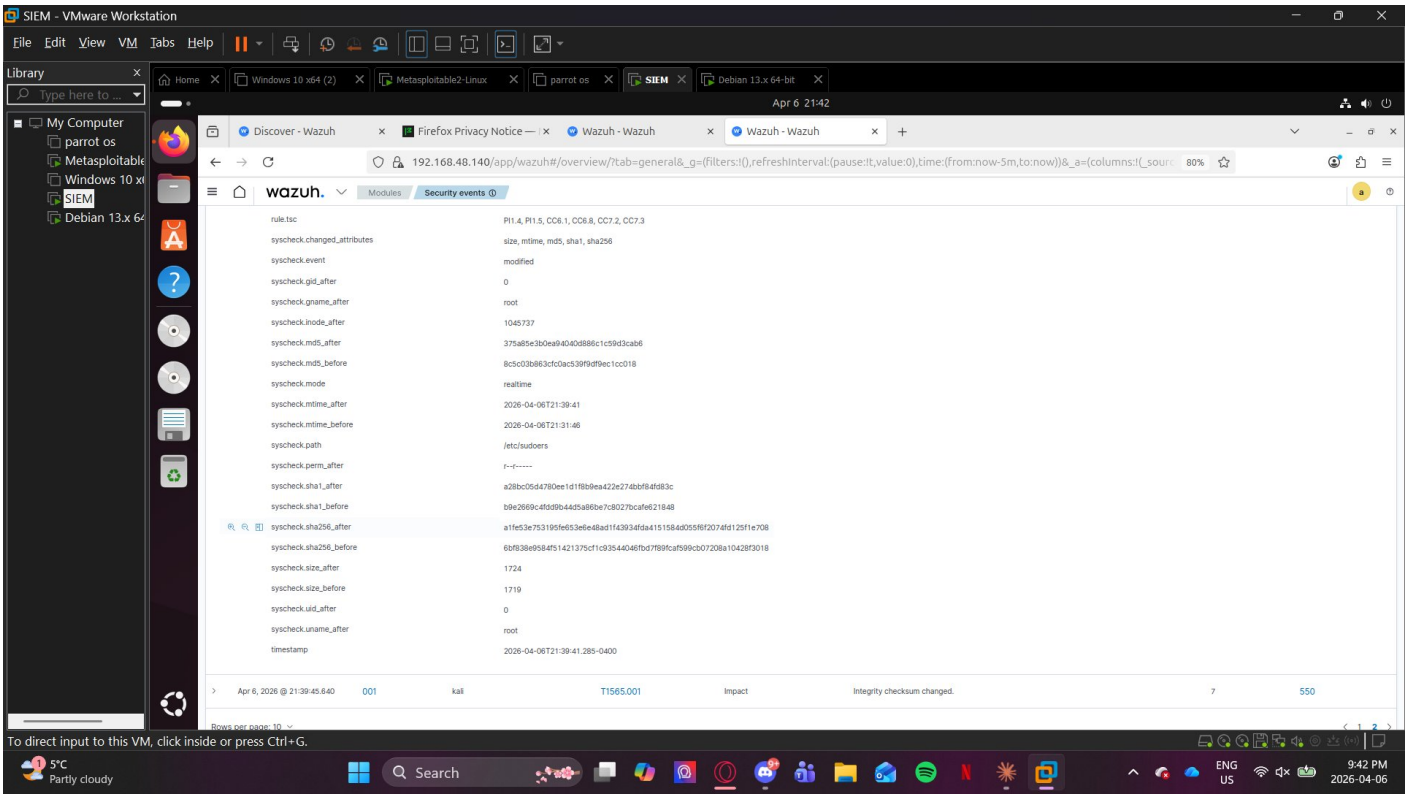

Figure 11: /etc/sudoers syscheck detail showing old and new SHA256, file owner root, TSC compliance

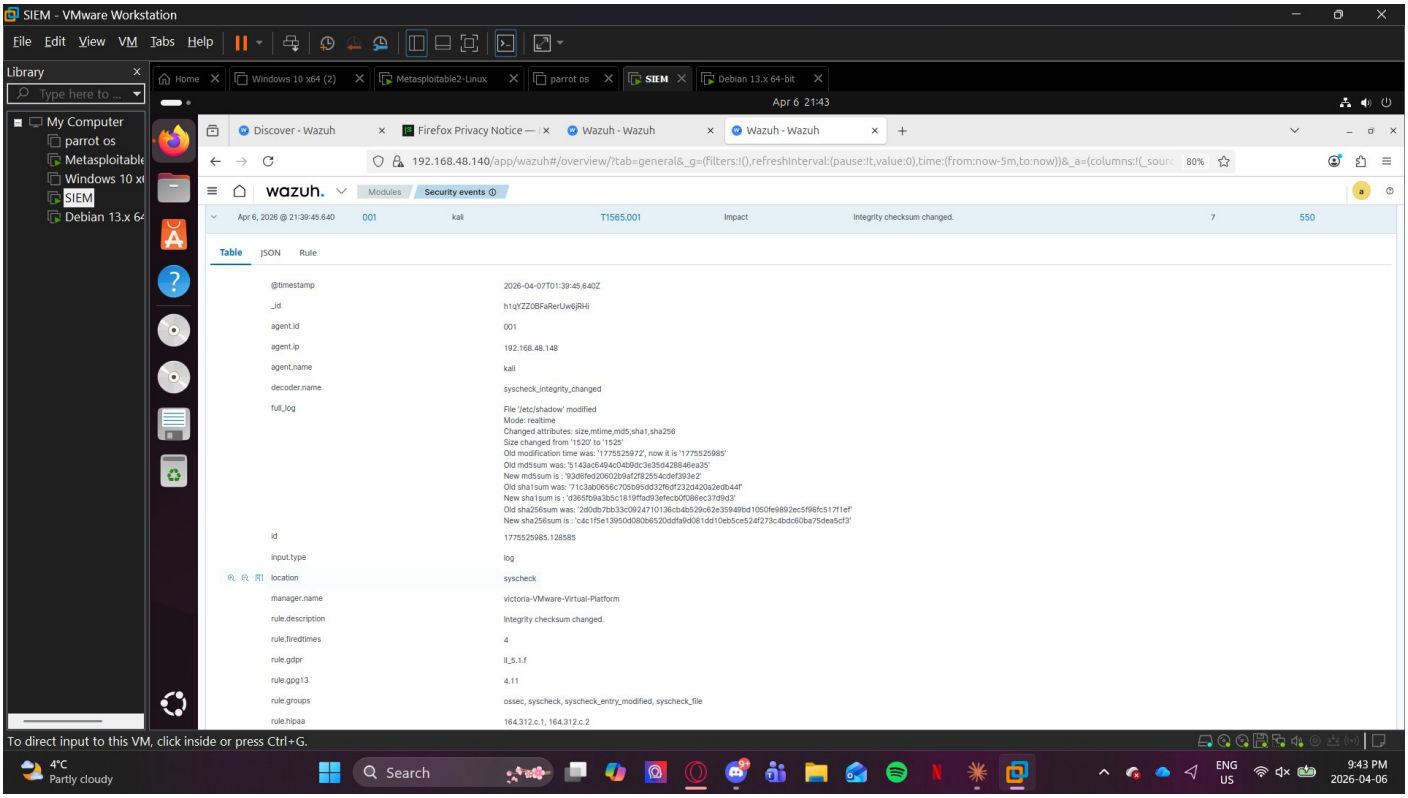

Figure 12: Second /etc/shadow modification caught, all hash fields changed again

Finding 4: Rogue Root Accounts

Two fake root accounts were added to the system to simulate attacker persistence. Both accounts were assigned UID 0, granting full root privileges. The OS itself flagged that the hacker account was outside the normal UID range. Wazuh detected the PAM session opening and automatically mapped it to four MITRE tactics.

```
Commands run: echo "root2:x:0:0:root:/root:/bin/bash" >> /etc/passwd   useradd -o -u 0 -g 0 -M hacker
PAM log: session opened for user root(uid=0) by victoria(uid=1000) MITRE: T1078   Tactics: Defense
Evasion, Persistence, Privilege Escalation, Initial Access
```

Finding 5: Defense Evasion (T1562.001)

The Wazuh agent was stopped three times during the exercise. Each time, Wazuh detected it had been stopped and generated an alert tagged with MITRE T1562.001. This shows that attempts to disable monitoring are still detected and logged.

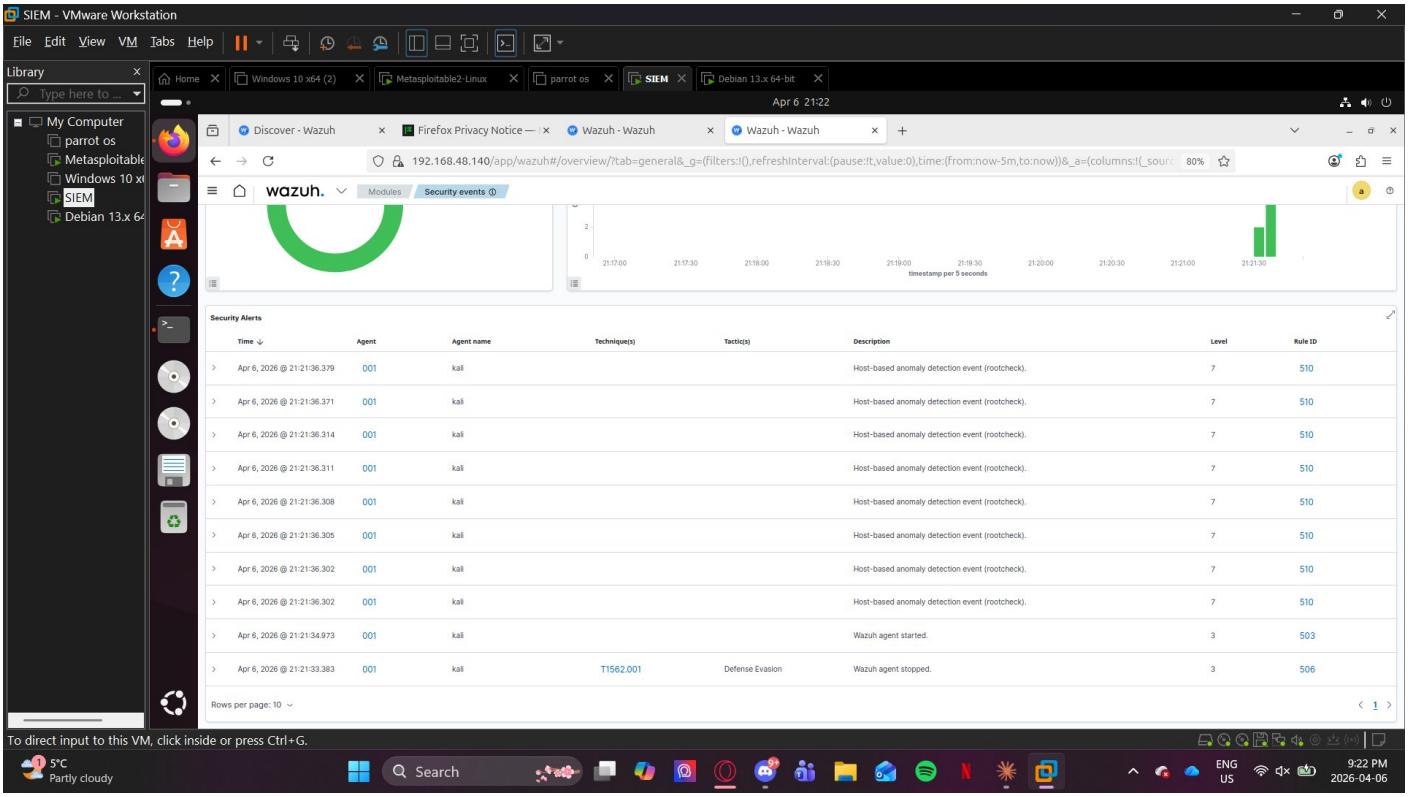

Figure 13: Defense Evasion alert T1562.001 showing agent stopped and restarted, rule 506

Finding 6: SSH Brute Force (T1110)

Hydra was run against the SSH service using the rockyou.txt wordlist, which contains over 14 million passwords. The attack was blocked due to connection limits, but all attempts were logged. Common usernames were also manually tested with incorrect passwords to generate failed authentication events.

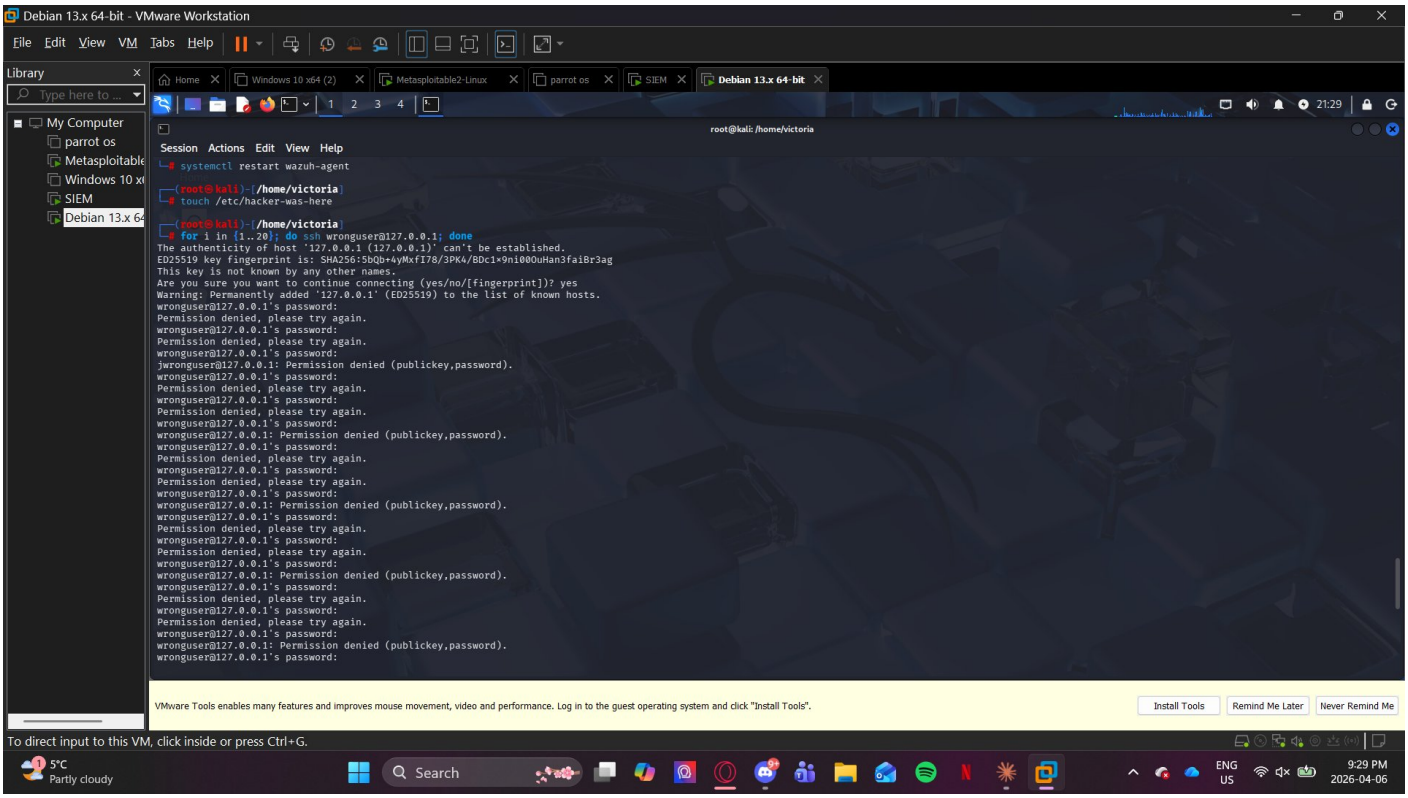

Figure 14: Hydra SSH brute force running against 127.0.0.1 with 14 million password attempts

Finding 7: SSH Hardening Failures

Wazuh SCA ran an automated audit of the SSH configuration and identified 9 issues, including root login being permitted, password authentication enabled, no retry limits configured, and the default port 22 in use.

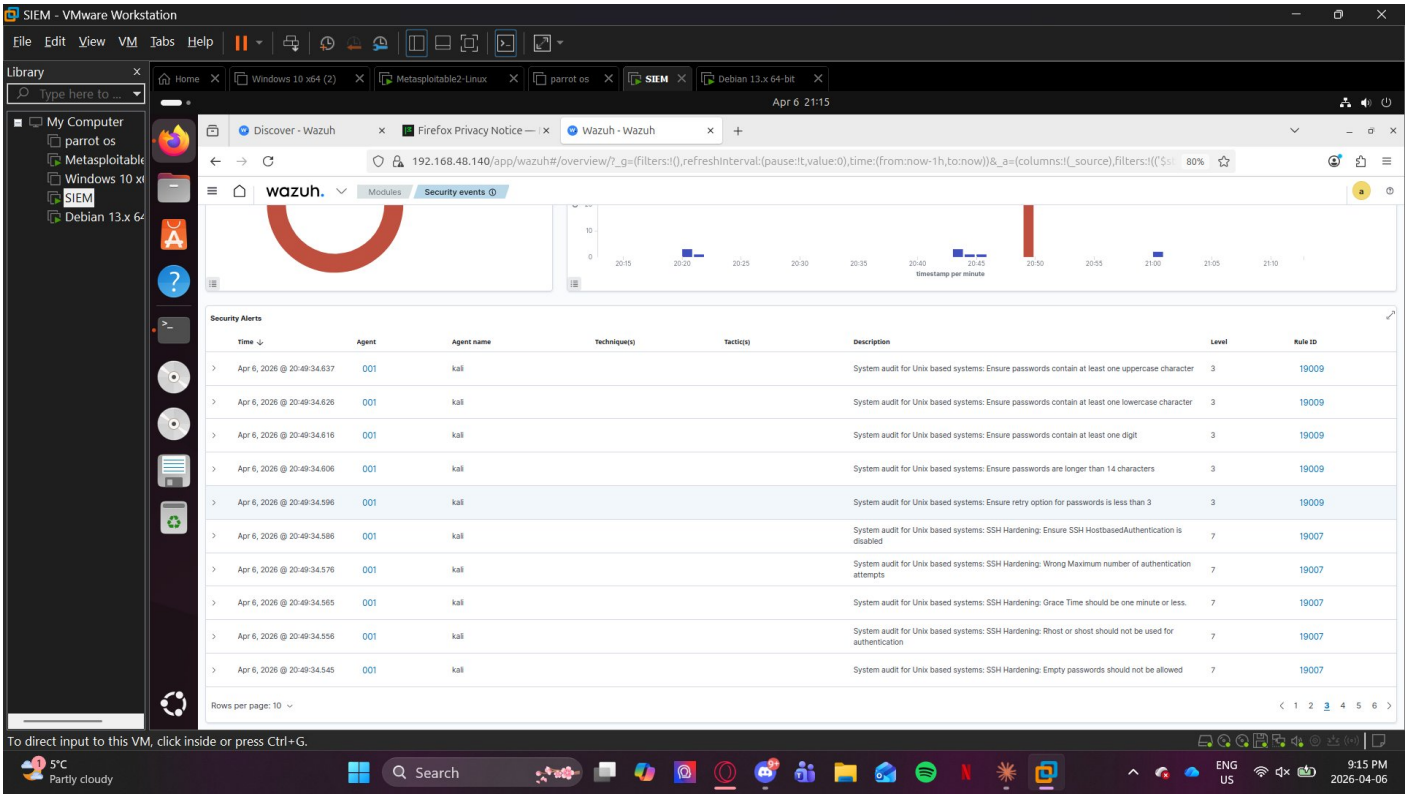

Figure 15: SCA audit results showing SSH password policy and configuration failures

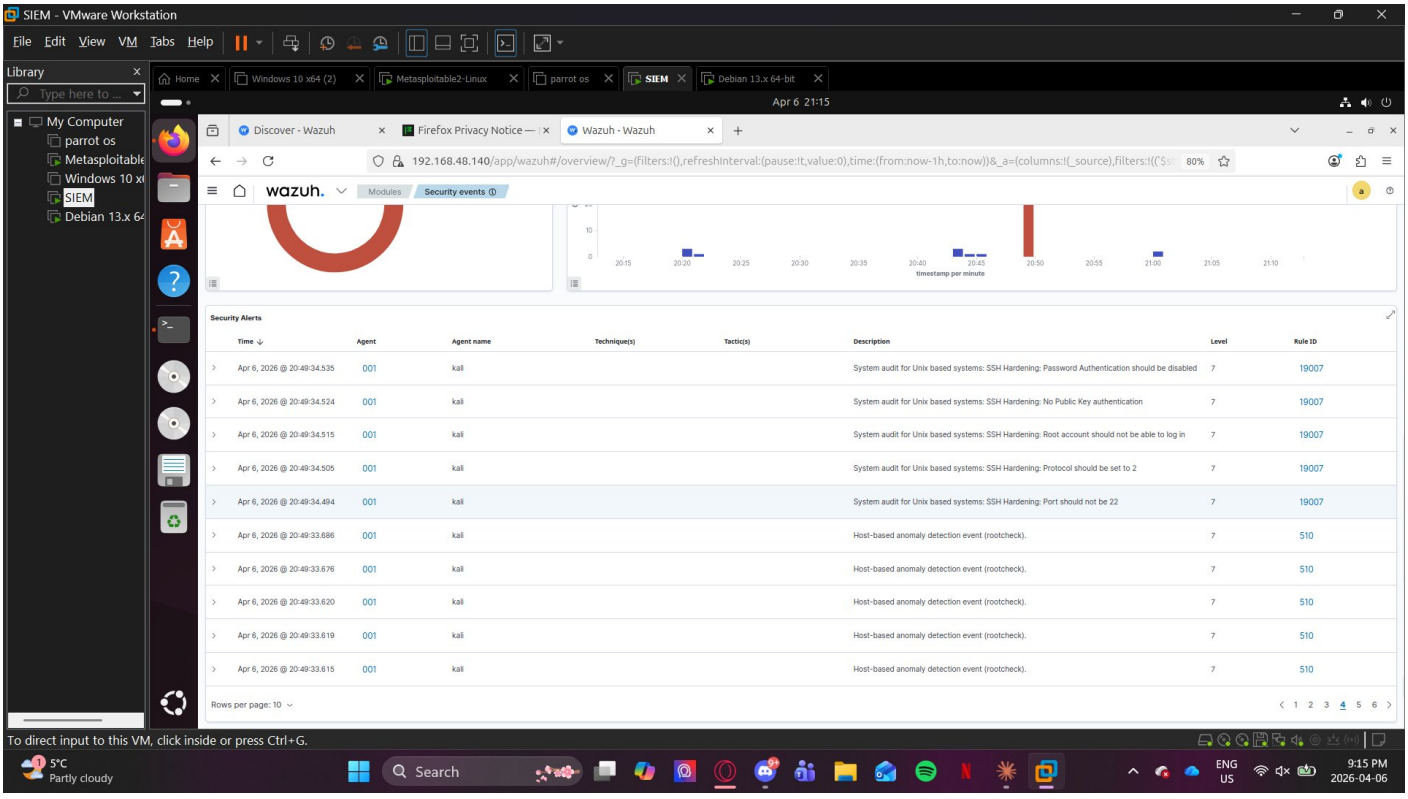

Figure 16: More SSH hardening failures including root login, empty passwords and protocol issues

5. MITRE ATT&CK; Mapping

Technique	Name	Tactic	Finding
T1014	Rootkit	Defense Evasion	Trojaned binaries
T1078	Valid Accounts	Persistence, Privilege Escalation	Rogue root accounts
T1110	Brute Force	Credential Access	SSH brute force
T1136	Create Account	Persistence	hacker and root2 added
T1562.001	Impair Defenses	Defense Evasion	Agent stopped 3 times
T1565.001	Stored Data Manipulation	Impact	/etc/shadow tampered

6. Indicators of Compromise

Type	Value	Notes
IP	192.168.48.148	Victim machine
File	/usr/bin/diff	Trojaned binary
File	/bin/diff	Trojaned binary
File	/bin/chsh	Trojaned binary
File	/etc/shadow	File was tampered with
File	/etc/sudoers	File was tampered with
File	/etc/passwd	Rogue root entry added
Account	root2	UID 0, created by attacker
Account	hacker	UID 0, created by attacker
MD5	5143ac6494c04b9dc3e35d428846ea35	/etc/shadow after tampering
MD5	375a85e3b0ea94040d886c1c59d3cab6	/etc/sudoers after tampering

7. Compliance Rules Triggered

Multiple compliance rules were triggered automatically without manual configuration. Wazuh mapped them on its own.

Framework	Rules Triggered
PCI-DSS	10.6.1
HIPAA	164.312.c.1, 164.312.c.2
GDPR	II_5.1.f, IV_35.7.d
NIST 800-53	AU:14, AC:7
GPG13	4.11
TSC	PI1.4, PI1.5, CC6.1, CC6.8, CC7.2, CC7.3

8. Remediation Recommendations

The following steps would be taken to remediate and harden this system in a real environment.

Priority	Action
Critical	Restore /etc/shadow and /etc/sudoers from a clean backup
Critical	Delete the rogue accounts root2 and hacker from /etc/passwd
Critical	Reinstall the trojaned binaries from a trusted package source
High	Disable root SSH login by setting PermitRootLogin no in sshd_config
High	Switch SSH to key-based authentication only and disable password auth
High	Move SSH off the default port 22
High	Set MaxAuthTries to 3 in sshd_config
Medium	Install fail2ban to automatically block brute force IPs
Medium	Enable AppArmor profiles for all services running on the machine
Medium	Enforce password policy through PAM configuration
Low	Restrict SSH to protocol version 2 only